

Fraud Detection

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 18: AI Security Use Cases

1. The Scale and Nature of the Fraud Problem

The Association of Certified Fraud Examiners (ACFE) 2024 Report to the Nations estimated that organizations lose approximately 5 percent of annual revenues to fraud — a global figure exceeding \$4 trillion annually. Financial services, healthcare, insurance, and e-commerce absorb the largest share.

Traditional fraud prevention relied on rigid rule sets: flag transactions over \$10,000, decline purchases from certain high-risk countries, require additional verification for specific merchant categories. The rules were well-intentioned but fundamentally brittle. Once fraudsters understood the rules — and they invested significant effort in understanding them — circumventing them was straightforward. Make transactions just under the threshold. Route transactions through merchant categories that aren't flagged. Use cards stolen in jurisdictions considered lower risk.

AI-driven fraud detection replaces brittle rules with statistical models that adapt continuously to evolving fraud patterns and build individualized behavioral baselines that rules can never replicate. The key advance is personalization: the model learns what normal looks like for each individual account and flags deviations, not just absolute thresholds.

Fundamental Shift: Rule-based fraud detection asks 'does this transaction match a known-bad pattern?' AI-based fraud detection asks 'does this transaction match this specific account holder's normal behavior?' The second question is far harder to game.

2. Individual Behavioral Baselines at Scale

Your transaction history — the merchants you frequent, the amounts typical for your purchases, the devices and networks you use, the hours you typically shop, the geographic areas where your purchases occur — constitutes a behavioral fingerprint. A trained model can recognize that fingerprint and identify deviations from it.

The operational scale at which this happens is important context for exam questions:

- Visa's AI-based authorization systems process more than 800 million transactions daily, assigning risk scores in approximately 300 milliseconds per transaction.
- Mastercard's Decision Intelligence applies AI to every transaction globally, incorporating more than 100 data points per authorization decision.
- The model considers not just merchant match and amount, but whether the purchase timing, location, and session behavior are consistent with the account's historical patterns.

A transaction that matches the account's behavioral profile gets approved transparently. One that deviates across multiple dimensions simultaneously — new merchant category, unusual amount, different device, atypical location — triggers a risk score that may initiate step-up authentication or decline.

3. Real-Time Transaction Scoring: Latency as a Design Constraint

Modern payment fraud systems operate at millisecond timescales. The fraud scoring model must complete its assessment within the time budget of the payment authorization protocol — typically 50 to 100 milliseconds from transaction submission to authorization response. This constraint has direct implications for model architecture that practitioners need to understand.

Model Type	Inference Latency	Suitability for Real-Time Fraud
Deep neural networks (large)	500ms - 2s	Too slow for real-time payment authorization
Gradient boosting (XGBoost, LightGBM)	5-20ms	Well-suited — fast inference, high accuracy
Shallow neural networks	10-50ms	Suitable depending on architecture
Logistic regression	1-5ms	Fastest; used for initial triage in tiered systems
Graph neural networks	100ms - 1s	Used for fraud ring detection, not per-transaction scoring

When evaluating fraud prevention vendors, the exam-relevant question is p99 inference latency under peak load, not average inference time. A model that averages 20ms but hits 500ms at p99 under Black Friday traffic is operationally problematic even if its average looks acceptable.

4. Card Testing and Account Takeover: Two Patterns the Exam References

Two specific fraud patterns appear frequently in exam questions:

- **Card Testing:** Fraudsters who obtain stolen card numbers must verify which cards are still active before attempting larger fraud. They make small purchases — often under \$5 at digital goods merchants (app stores, game platforms, subscription services that process instantly) — to test which cards are live. AI detects card testing by recognizing the statistical signature: unusually small transactions across multiple cards in rapid succession from the same device or IP address. A single device testing 40 cards in 20 minutes is a pattern no legitimate user generates.
- **Account Takeover (ATO):** A fraudster has obtained legitimate credentials — through phishing, credential stuffing using breach list data, or social engineering — and logs in as a legitimate user. The challenge: the login itself may succeed (valid credentials), making credential-based detection insufficient. AI detects ATO by identifying that the session behavior doesn't match the account holder's established patterns: different typing speed, different navigation sequence, different device fingerprint, different geolocation, different time of day than the account's historical access patterns.

5. Behavioral Biometrics: The Passive Continuous Authentication Layer

Behavioral biometrics is one of the more counterintuitive fraud detection capabilities: the way a user types, moves a mouse, holds a phone, navigates an application, and interacts with a touchscreen is individually distinctive at a statistical level — distinctive enough to serve as a continuous authentication signal.

Three specialized providers in this space worth knowing by name:

- BioCatch — embeds a JavaScript component in web applications to collect continuous behavioral signals; builds a profile over time and scores each session against the established profile. BioCatch reports detecting more than \$1 billion in fraud losses annually across their customer base using behavioral biometrics alone.
- Sardine — behavioral intelligence platform targeting digital financial services onboarding and transaction monitoring.
- NeuroID — focuses on behavioral signals during the account opening and onboarding process, where synthetic identity fraud is most concentrated.

The capability that makes behavioral biometrics powerful against ATO: a fraudster who has obtained the victim's credentials, device, and even knows their transaction patterns still behaves differently at the keyboard and touchscreen. The muscle memory, response timing, and navigation patterns that accumulate over months of device use are not transferable through a credential compromise.

Real-World Case — Account Takeover Detection via Behavioral Biometrics (BioCatch, 2021): A major European bank deployed BioCatch across their online banking platform. During a credential stuffing campaign that successfully authenticated thousands of accounts using breached username/password pairs, BioCatch's behavioral models flagged 94 percent of the fraudulent sessions within the first 30 seconds of activity — before the attacker had initiated any transactions — because the behavioral signatures were statistically inconsistent with the account holders' established profiles. Traditional credential-based authentication would have approved all sessions as valid logins.

6. Network Analysis and Fraud Ring Detection

Individual transaction analysis is insufficient to detect coordinated fraud operations. Sophisticated fraud rings operate multiple accounts in coordination — accounts that individually appear below fraud thresholds but reveal their connection through shared infrastructure.

AI-powered graph analysis engines identify these connections by building a graph of relationships between accounts, devices, IP addresses, phone numbers, email addresses, and behavioral patterns. When accounts A, B, and C were all created from the same IP address, have all made purchases at the same small set of merchants, and have all received transfers from account D, the graph reveals coordinated fraud that individual transaction analysis misses.

- SAS Fraud Management — enterprise analytics platform with graph-based fraud ring detection.
- FICO Falcon Platform — widely deployed in financial services; uses behavioral profiling and network analytics.
- Featurespace ARIC — adaptive behavioral analytics platform using Bayesian learning to detect novel fraud patterns.

The operational value of fraud ring detection: disrupting the ring is more cost-effective than catching individual fraudulent transactions. A ring of 50 coordinated accounts generating \$5,000 in fraud each represents \$250,000 in exposure; catching one account at a time recovers \$5,000 per detection while the ring continues operating.

7. Synthetic Identity Fraud: The Long Game

Synthetic identity fraud is among the most sophisticated and difficult-to-detect fraud types because the attack is designed to appear legitimate for months or years before the payoff.

The mechanics: fraudsters create new identities using fabricated or partially real information — often real Social Security numbers belonging to children or recent immigrants with thin credit files, combined with fabricated names, addresses, and phone numbers. They use these synthetic identities to apply for secured credit cards, build payment history over 12-24 months, and gradually accumulate higher credit limits. Then they execute the bust-out: maxing out all available credit across multiple accounts simultaneously and disappearing.

Traditional anomaly detection fails against synthetic identity because the account behavior during the buildup phase is deliberately constructed to appear legitimate. AI-based detection approaches the problem differently:

- Identity element consistency analysis — checking whether the combination of name, SSN, address, and phone number is internally consistent across multiple data sources, or whether it shows patterns of fabrication (the SSN was issued in a state inconsistent with the applicant's stated birthplace, for example).
- Application velocity analysis — detecting when the same or similar identity elements appear in multiple credit applications across institutions within a short period.
- Network connection analysis — identifying when apparently independent synthetic identities share device fingerprints, email patterns, or behavioral signatures that reveal common authorship.

Mastercard Identity Check and LexisNexis Fraud Intelligence both incorporate ML-based synthetic identity scoring that combines these signals into a risk assessment at the point of application.

8. Red Team Perspective: How Fraudsters Evade Detection

Professional fraud attackers study the boundaries of detection systems with the same rigor that security researchers study defensive tools. Understanding evasion techniques is directly applicable to building more robust models.

- Money mule layering — using a chain of legitimate-looking accounts to launder proceeds through transactions that individually appear legitimate; the final destination is separated from the fraud by multiple hops.
- Amount ramping — slowly increasing transaction amounts over time to stay within the model's expected deviation range for the account; avoids the sudden spike that triggers deviation alerts.
- Device acquisition — purchasing legitimate devices from secondary markets (eBay, Facebook Marketplace) that have a device fingerprint history, defeating device-based detection.
- Residential proxy networks — using IP addresses consistent with the victim's geographic location, defeating location-based anomaly detection.

The implication for model design: models that rely on a single strong signal (location, device, amount) are easier to evade than models that correlate dozens of weak signals simultaneously. An attacker can defeat one signal type; defeating 50 correlated signals simultaneously requires sophistication that most

fraud operators cannot sustain. This principle — multi-signal correlation defeating single-signal evasion — applies broadly to any ML-based security detection system.

9. Adaptive Learning, Model Refresh, and Feature Drift

Fraud patterns evolve continuously. A detection model that achieves 97 percent accuracy in January may degrade to 85 percent accuracy by July as fraudsters adapt their techniques in response to detection signals. Responsible fraud AI deployment requires active model management:

- Continuous performance monitoring — tracking model performance against confirmed fraud outcomes (ground truth labels from investigations) rather than relying on surrogate metrics.
- Scheduled retraining — periodic model updates incorporating recent fraud patterns into the training data.
- Emergency model updates — mechanisms to quickly deploy model changes when a new fraud pattern is detected that the current model is missing.
- **Feature drift monitoring:** When the statistical distribution of input features changes — because the customer base grew, the transaction mix shifted, or a new product line was launched — model performance can degrade silently without any obvious alert. DataRobot, H2O.ai, and vendor-specific MLOps platforms provide drift monitoring that tracks feature distributions and model performance metrics over time, alerting when drift thresholds are exceeded.

10. Explainability in Fraud Operations

Fraud analysts who investigate flagged transactions need to understand why a transaction was flagged to evaluate it efficiently. A model that returns only a risk score of 0.87 without contributing factors forces analysts to investigate from scratch — and regulators increasingly require that such explanations be available.

Modern fraud platforms incorporate explainability methods:

- **SHAP (SHapley Additive exPlanations):** Assigns each input feature a contribution value to a specific prediction. 'This transaction scored 0.87 because: device fingerprint is new (+0.31), merchant category inconsistent with account history (+0.24), transaction amount is 340 percent above 90-day average (+0.19), transaction time is atypical for this account (+0.13).' The analyst has an immediate investigation starting point.
- **LIME (Local Interpretable Model-agnostic Explanations):** Approximates the model's behavior in the vicinity of a specific prediction using an interpretable surrogate model; produces similar feature attribution outputs.

The regulatory motivation for explainability: CFPB guidance published in 2023 clarified that adverse action notices — required when credit or financial services are denied — must provide specific reasons even when the denial was driven by a complex ML model. FinCEN guidance on AI in AML/KYC contexts similarly requires that AI decisions be explainable. These regulatory requirements affect model selection for fraud scoring: opaque models require additional explainability infrastructure; inherently interpretable models (logistic regression, decision trees) avoid this requirement but may sacrifice accuracy.

11. Compliance and Regulatory Context

Regulation	Requirement Relevant to Fraud AI
Bank Secrecy Act (BSA)	Suspicious Activity Reports (SARs) required for transactions indicating money laundering; AI fraud flags must generate SAR-ready documentation
FinCEN AI/AML guidance	AI decisions in AML/KYC contexts must be explainable; motivates XAI approaches or interpretable model selection
CFPB guidance (2023)	Adverse action notices must provide specific reasons even when denial was driven by a complex ML model
EU PSD2	Strong Customer Authentication required; transaction abandonment rates must stay below regulatory thresholds (false positive constraint)
FCRA (Fair Credit Reporting Act)	Data used in credit decisions subject to accuracy and dispute resolution requirements; applies to fraud scoring that affects credit access

The PSD2 tension is worth noting for exam questions: the regulation simultaneously requires Strong Customer Authentication (which increases friction) and imposes limits on transaction abandonment rates (which penalizes false positives that add friction). Fraud teams must balance security and user experience within a regulatory framework that constrains both.

Key Terms Glossary

Term	Definition
Behavioral baseline	Statistical model of an individual account holder's normal transaction patterns — merchants, amounts, devices, locations, timing — used to detect deviations indicative of fraud.
Card testing	Fraud technique using small test transactions to verify which stolen card numbers are active before attempting larger fraudulent purchases.
Account takeover (ATO)	Fraud in which an attacker with valid credentials logs in as a legitimate user; detected by behavioral biometrics rather than credential validation.
Behavioral biometrics	Fraud detection approach using how a user types, moves a mouse, or navigates an application as a continuous passive authentication signal.
BioCatch	Behavioral biometrics provider that embeds JavaScript in web applications to build behavioral profiles and score sessions for ATO detection.
Synthetic identity fraud	Creating new identities from fabricated or partially real information; building credit over months before busting out. Detected by identity element consistency and network analysis.
Bust-out	Final phase of synthetic identity fraud: simultaneous maxing of all credit lines across accounts before the fraudster disappears.

SHAP	SHapley Additive exPlanations — method for explaining individual ML predictions by attributing feature-level contributions to the prediction score.
Feature drift	Change in the statistical distribution of model input features over time; silently degrades model performance without triggering obvious alerts.
Money mule	Account used to receive and transfer fraudulent proceeds, layering legitimate-looking transactions between the original fraud and the final beneficiary.

Quick Revision Checklist

- ACFE 2024 estimates organizations lose 5 percent of revenues to fraud — over \$4 trillion globally.
- Visa processes 800 million transactions daily with AI risk scoring in approximately 300 milliseconds.
- Real-time fraud scoring requires low-latency models — gradient boosting preferred over deep neural networks for transaction authorization.
- Card testing: small transactions across multiple cards from same device/IP to verify which are active.
- Account takeover detected by behavioral biometrics mismatch, not credential validation failure.
- BioCatch, Sardine, and NeuroID are the key behavioral biometrics providers.
- Graph analysis (SAS, FICO Falcon, Featurespace ARIC) detects fraud rings where individual accounts appear below threshold.
- Synthetic identity fraud: fabricated identities build credit over months before bust-out; detected via identity element consistency and network analysis.
- Multi-signal correlation defeats single-signal evasion — models relying on one indicator are easier to game.
- SHAP and LIME provide fraud model explainability to satisfy CFPB adverse action notice requirements.
- CFPB 2023 guidance: adverse action notices must provide specific reasons even for ML-driven denials.
- Feature drift silently degrades model performance — requires continuous monitoring via MLOps platforms.

10 Exam-Based MCQs — Fraud Detection

Test yourself after reading. These questions follow the CompTIA SecAI+ exam style — scenario-based with plausible distractors. Read every explanation including for correct answers.

Q1. Scenario: A payment network's fraud engineering team is selecting a model architecture for real-time transaction scoring. They need a model that can assess risk for each transaction within the authorization protocol's time budget while maintaining high detection rates. What is the PRIMARY reason gradient boosting models (XGBoost, LightGBM) are preferred over large deep neural networks for real-time payment transaction fraud scoring?

- A) Gradient boosting models achieve higher fraud detection accuracy than deep neural networks

- B) Gradient boosting models produce inference results within the 50-100 millisecond authorization window that deep neural networks exceed
- C) Deep neural networks require more training data than is available for fraud detection use cases
- D) Regulatory requirements prohibit the use of deep neural networks in financial fraud systems

Answer: B **Explanation:** B is correct because real-time payment authorization operates within a strict 50-100 millisecond time budget. Gradient boosting models produce inference in 5-20ms; large deep neural networks typically require 500ms or more. The latency constraint, not accuracy, drives model architecture selection for transaction scoring. A is wrong because deep neural networks often match or exceed gradient boosting accuracy on fraud datasets — the limitation is not accuracy but inference speed. C is wrong because modern payment networks have abundant training data; data volume is not the constraint. D is wrong because there is no regulatory prohibition on deep neural networks in fraud systems; inference latency is the practical constraint.

Q2. A fraud analyst observes that a single IP address submitted 40 small transactions (each under \$3) to 40 different card numbers at a digital goods merchant within 18 minutes. Which fraud pattern does this MOST likely represent?

- A) Account takeover — an attacker is testing compromised credentials
- B) Card testing — an attacker is verifying which stolen card numbers are active
- C) Synthetic identity fraud — an attacker is building credit history across multiple accounts
- D) Money mule layering — an attacker is moving funds through multiple accounts

Answer: B **Explanation:** B is correct because card testing involves making small transactions across multiple card numbers from a common source to verify which cards are active before larger fraud attempts. The signature — small amounts, multiple cards, rapid succession, single source IP, digital goods merchant (immediate processing) — is the textbook card testing pattern. A is wrong because ATO involves testing credentials for a single account, not small purchases across many card numbers. C is wrong because synthetic identity fraud involves building credit history over months using fabricated identities, not rapid small transactions across stolen card numbers. D is wrong because money mule layering moves funds through account transfers, not small test purchases across card numbers.

Q3. Scenario: A fraud investigator is reviewing a case where a customer's laptop was stolen from their car. Three days later, someone logged into the customer's online banking using the customer's saved credentials from the browser and the stolen laptop from the same city as the victim's home address. A fraudster successfully logs into a customer's online banking account using credentials obtained through a phishing attack. The device used is the victim's actual laptop, obtained through physical theft. Which detection approach is MOST likely to identify the fraudulent session?

- A) Multi-factor authentication challenge sent to the account holder's phone number
- B) IP address geolocation anomaly detection
- C) Behavioral biometrics analysis of typing speed, navigation patterns, and session behavior
- D) Device fingerprint matching against the account's registered devices

Answer: C **Explanation:** C is correct because the attacker has valid credentials and the victim's actual

device — defeating both credential-based and device fingerprint-based detection. Behavioral biometrics captures how the user interacts (typing rhythm, mouse movement, navigation sequence) which differs between the legitimate account holder and the attacker even on the same device. A is wrong because if the attacker has also stolen or SIM-swapped the victim's phone, MFA may also be compromised; additionally, this scenario specifies the device was stolen suggesting physical access. B is wrong because if the attacker is operating from the same geographic location (the stolen device may be used locally), geolocation anomaly detection may not trigger. D is wrong because the attacker is using the victim's actual device, so device fingerprint matches the registered device.

Q4. Which of the following BEST describes the concept of 'bust-out' in the context of synthetic identity fraud?

- A) The fraudster's initial attempt to open accounts using a synthetic identity, which may be rejected
- B) The simultaneous maxing of all available credit lines across accounts after an extended period of building credit history
- C) The detection event when a fraud model identifies a synthetic identity account
- D) The process of layering transactions through multiple money mule accounts to obscure fraud proceeds

Answer: B **Explanation:** B is correct because bust-out is the terminal phase of a synthetic identity fraud scheme: after spending months or years building a positive credit history and increasing credit limits, the fraudster simultaneously maxes out all available credit across multiple accounts and disappears. The extended buildup phase is specifically designed to enable this high-value terminal event. A is wrong because this describes the application phase, not the bust-out. C is wrong because bust-out is the fraudster's action, not the detection event. D is wrong because layering through money mule accounts is a money laundering technique, distinct from the bust-out phase of synthetic identity fraud.

Q5. A bank's fraud model achieves 96 percent accuracy in Q1 but degrades to 81 percent by Q4 without any change to the model code. What is the MOST likely explanation?

- A) The training dataset was too small and the model overfit to the Q1 data
- B) Feature drift — the statistical distribution of input features changed as the customer base or transaction mix evolved, degrading model performance
- C) The fraud operations team failed to update the rule-based override layer that supplements the model
- D) Regulatory changes in Q2 required new transaction types that the model had never seen during training

Answer: B **Explanation:** B is correct because feature drift is the most common cause of silent model performance degradation without code changes. As the customer base grows, seasonality shifts transaction patterns, new products change the merchant category mix, and fraud patterns evolve — the statistical distributions the model was trained on no longer match production data. A is wrong because overfitting would show up as poor generalization during initial deployment, not gradual degradation over months of production use. C is wrong because the question specifies no change to the model code, and rule-based override failures would cause specific pattern misses rather than broad accuracy degradation. D is wrong

because the question asks for the most likely explanation; regulatory changes are possible but feature drift from normal operational change is far more common.

Q6. The CFPB's 2023 guidance on ML-based denial decisions requires which of the following?

- A) That all ML-based fraud models be replaced with logistic regression models to ensure interpretability
- B) That adverse action notices provide specific reasons for denial even when the denial was driven by a complex ML model
- C) That financial institutions submit their fraud model architecture to CFPB for pre-approval before deployment
- D) That all fraud scoring models use only features explicitly permitted in Regulation B

Answer: B **Explanation:** B is correct because the CFPB's 2023 guidance clarified that adverse action notice requirements — which mandate specific reasons when credit or financial services are denied — apply regardless of whether the denial was driven by a complex ML model. This creates an explainability requirement that affects model selection and requires XAI tooling (SHAP, LIME) for black-box models. A is wrong because the guidance does not require replacement of complex models with interpretable ones; it requires that explanations be produced, which can be achieved through XAI techniques. C is wrong because there is no pre-approval requirement for fraud model architecture. D is wrong because Regulation B governs discrimination in credit decisions; while relevant to disparate impact analysis, it does not enumerate a specific permitted feature list for fraud scoring.

Q7. Why is graph-based network analysis valuable for detecting fraud rings that individual transaction analysis misses?

- A) Graph analysis is faster than transaction analysis and can process more transactions per second
- B) Individual accounts in a fraud ring may each score below the fraud threshold; the graph reveals shared infrastructure that exposes their coordination
- C) Graph analysis provides regulatory-compliant explanations that transaction scoring alone cannot produce
- D) Fraud rings always use the same device fingerprint, which graph analysis is specifically designed to detect

Answer: B **Explanation:** B is correct because fraud rings are specifically constructed so that each individual account appears legitimate below detection thresholds. The coordination signal — shared IP address at account creation, shared device, common transaction counterparties, identical behavioral patterns — is only visible at the network level, not through analyzing each account in isolation. A is wrong because graph analysis is typically computationally more expensive than individual transaction scoring; it's not used for its speed but for its ability to reveal relationships. C is wrong because explainability is not the primary value proposition of graph analysis. D is wrong because fraud rings do not always use the same device fingerprint — in fact, sophisticated rings specifically use different devices to avoid fingerprint-based detection; graph analysis catches other relationship signals.

Q8. A payment fraud team discovers that fraudsters have been successfully evading their location-based anomaly detection by using residential proxy networks. What model design principle would MOST reduce the effectiveness of this evasion technique?

- A) Implementing a more sophisticated geolocation database with better residential IP identification
- B) Correlating dozens of weak signals simultaneously so that defeating one signal type is insufficient to evade detection
- C) Adding a customer notification step that allows account holders to confirm unusual locations
- D) Applying stricter geographic restrictions for all transactions originating from IP addresses in high-risk regions

Answer: B **Explanation:** B is correct because the fundamental defense against single-signal evasion is multi-signal correlation. A fraudster using a residential proxy can defeat the location signal, but simultaneously defeating location, device behavioral biometrics, typing rhythm, merchant pattern, amount profile, and session navigation — all at once — is prohibitively complex. Multi-signal models make point evasion insufficient. A is wrong because better geolocation databases improve accuracy but still rely on a single signal type that sophisticated attackers can invest in defeating. C is wrong because customer notification adds friction to legitimate transactions and does not change the underlying model's susceptibility to evasion. D is wrong because geographic restrictions are a blunt instrument that increases false positives for legitimate travelers while fraudsters simply move to proxies in different regions.

Q9. Under the EU's Revised Payment Services Directive (PSD2), what tension does Strong Customer Authentication create for AI-based fraud detection systems?

- A) SCA requires AI systems to achieve 99.9 percent fraud detection accuracy, which conflicts with acceptable false positive rates
- B) SCA increases authentication friction while PSD2 also requires that transaction abandonment rates remain below regulatory thresholds, creating a conflict between security and user experience
- C) SCA prohibits the use of behavioral biometrics as an authentication factor, limiting AI-based detection options
- D) SCA requires that all fraud decisions be made by human analysts rather than automated AI systems

Answer: B **Explanation:** B is correct because PSD2 creates a regulatory tension: it mandates Strong Customer Authentication (which adds friction to transactions) while also limiting acceptable transaction abandonment rates (which penalizes excessive friction). Fraud teams must calibrate their models to catch fraud while keeping false positives low enough that authentication challenges don't drive abandonment above the regulatory limit. A is wrong because PSD2 does not specify a 99.9 percent accuracy requirement for AI systems. C is wrong because PSD2 does not prohibit behavioral biometrics; in fact, behavioral factors can qualify as one of the authentication elements under SCA. D is wrong because PSD2 does not require human analyst review for all fraud decisions.

Q10. *Scenario:* A fraud operations analyst receives a call from the CFO of a small business whose \$47,000 wire transfer was declined by the bank's AI fraud model. The analyst needs to explain the decline to the customer and assess whether to override the model decision. A fraud model returns a risk score of

0.91 for a business wire transfer, which triggers a decline. The business owner calls to dispute the decline and the fraud analyst needs to explain the reasoning. Which approach provides the MOST operationally useful explanation?

- A) Inform the business owner that the model score exceeded the threshold without additional detail, as the model is proprietary
- B) Use SHAP values to identify which features contributed most to the 0.91 score and explain those specific factors to the analyst and customer
- C) Rerun the transaction through a simpler logistic regression model to generate a more interpretable score
- D) Apply the Global Interpretable Model-agnostic Explanations (GIME) framework to generate a population-level explanation

Answer: B **Explanation:** B is correct because SHAP (SHapley Additive exPlanations) provides local explanations — feature contributions to a specific individual prediction, not population-level averages. 'This transaction was scored 0.91 because the beneficiary account is new (contributing +0.28), the wire amount is 340 percent above this account's 90-day average (+0.22), and the origination device is unrecognized (+0.18)' gives the analyst an immediate investigation starting point and satisfies the CFPB adverse action notice requirement. A is wrong because CFPB guidance requires specific reasons for adverse actions, not just a score threshold reference. C is wrong because rerunning through a different model changes the decision logic and is not a valid explanation of why the original model scored the transaction as it did. D is wrong because GIME is not a recognized XAI framework; SHAP and LIME are the standard tools, and population-level (global) explanations do not satisfy the requirement for individual transaction explanations.